

BEFORE Placeholder

AFTER

Contract Clauses — Audit & Assurance (Template Library)

Document classification: Internal template (for contracts)

Template owner: Legal Counsel (terms) / Security Engineering & Architecture (assurance requirements)

Version: 0.1

Effective date: _____

Note: Select clauses proportionate to supplier tier and service scope. Use these as modular clauses or as a section in a Security Schedule.

A) Assurance evidence provision (preferred model)

A1 — Provision of assurance reports Supplier shall, upon request and subject to reasonable confidentiality restrictions, provide assurance evidence relevant to the Services, which may include:

- ISO 27001 certificate and scope (if applicable), and/or
- SOC report (where available), and/or
- independent security testing summary (e.g., penetration test executive summary) relevant to the Services, and/or
- other independent assurance evidence reasonably sufficient to demonstrate control effectiveness for the Services.

A2 — Frequency Supplier shall provide the assurance evidence:

- on commencement (where available),
- on renewal, and
- no more frequently than annually unless a material incident or material change occurs.

A3 — Relevance Supplier may provide reports covering the broader service, provided the scope includes the Services used by the Customer and the relevant control areas (identity/access, logging, vulnerability management, incident response, sub-processors).

B) SOC/ISO-specific wording (if applicable)

B1 — SOC report provision Where Supplier obtains a SOC report relevant to the Services, Supplier shall provide a copy of the SOC report (Type II preferred where available) and management response (if provided), subject to confidentiality restrictions.

B2 — ISO certificate provision Where Supplier maintains ISO 27001 certification relevant to the Services, Supplier shall provide the certificate and scope statement, and shall notify the Customer of material changes to certification status or scope.

C) Customer assurance questions and reasonable information rights

C1 — Reasonable information rights Supplier shall respond to reasonable written security assurance questions relating to the Services, within a reasonable timeframe, and shall provide clarification or supplementary evidence where necessary to address material risks.

C2 — Material control changes Supplier shall notify the Customer without undue delay of any material reduction in security controls relevant to the Services (e.g., loss of logging, loss of MFA enforcement for admin access, major outsourcing changes), and shall cooperate to agree mitigations.

D) Incident-driven evidence and cooperation (Critical recommended)

D1 — Incident-driven evidence Following a material security incident affecting the Services and/or Customer data, Supplier shall provide additional evidence reasonably required to:

- determine whether Customer data or systems were affected,
- support Customer's investigation and response, and
- demonstrate corrective actions and control improvements.

D2 — Forensics and log support Supplier shall preserve and make available relevant logs and evidence for the incident period for an agreed period and provide such information upon request, subject to confidentiality and legal restrictions.

E) Audit rights (pragmatic, proportionate)

E1 — Audit via third-party reports (default) The parties agree that assurance obligations will be satisfied primarily through the provision of independent third-party assurance reports and reasonable information rights under Sections A–D.

E2 — On-site/remote audit (exceptional) Where independent assurance evidence is not available or is insufficient for the Services and risk profile, and the parties cannot otherwise agree reasonable alternative evidence, Customer may request a security audit limited to the Services in scope, subject to:

- reasonable notice (e.g., 30–60 days),
 - scope and timing agreed in advance,
 - audit performed by Customer or an independent auditor bound by confidentiality,
 - audit limited to controls relevant to the Services,
 - reasonable restrictions to protect other customers and Supplier confidential information,
 - audit no more than once annually unless triggered by a material incident.
-

F) Confidentiality and handling of assurance materials

F1 — Confidential treatment Customer shall treat assurance materials (SOC reports, pen test summaries, security documentation) as confidential and shall restrict access to personnel with a need to know (e.g., Security, Technology Risk, Legal, auditors).

F2 — No redistribution Customer shall not redistribute assurance materials outside the organisation except to professional advisors/auditors under confidentiality obligations, unless required by law or regulator.

G) Remediation commitments for material findings (Critical recommended)

G1 — Remediation of material findings Where assurance evidence identifies material findings relevant to the Services, Supplier shall provide a remediation plan with target dates and provide status updates on request.

G2 — Customer notification of material issues Supplier shall notify Customer of material findings or vulnerabilities affecting the Services where exploitation is known or reasonably suspected, together with mitigation guidance.

H) Tier guidance (selection)

Critical (Tier 1) recommended minimum set:

- A1–A3
- C1–C2
- D1–D2
- F1–F2
- G1 (and G2 where applicable)
- E1 and E2 (as a fallback where evidence is insufficient)

Important (Tier 2) recommended minimum set:

- A1–A3
- C1
- F1–F2
- D1 (optional, where service is material)

Low (Tier 3) proportionate set:

- C1 (lightweight)
 - F1 (where assurance materials are shared)
-

I) Practical fallback positions (if supplier pushes back)

If supplier refuses on-site audit rights:

- strengthen A/C/D (more structured evidence rights), and/or
- require annual SOC/ISO/pen test executive summary delivery, and/or
- require incident-driven evidence and log support as non-negotiable for Critical scope.